

External Penetration Testing Report

Prepared For: MD. Shadman Sadique

Prepared By: Nowrin Haque

Assessment Scope:

- Active Reconnaissance
- OWASP Juice Shop
- Blue Room Exploitation

Date: 18 May 2026

The assessment included:

- Active Reconnaissance
- OWASP Juice Shop Web Application Testing
- Windows Exploitation (Blue Room)

The testing was conducted using Kali Linux, Nmap, Burp Suite, Metasploit Framework, and other standard penetration testing tools.

Active Reconnaissance

Objective

The objective of the reconnaissance phase was to gather information about the target systems and identify exposed services, open ports, and possible entry points.

Process

During this phase, Nmap was used to perform host discovery and service enumeration. The target system was scanned to identify open ports and running services. Different Nmap scan types were used to gather detailed information about the target environment.

The reconnaissance process identified multiple open ports and services such as HTTP, SMB, and RPC. Service enumeration also revealed version information which could later be used to identify known vulnerabilities.

Findings

The target exposed several services publicly. SMB services were enabled and accessible externally, which significantly increased the attack surface. Service fingerprinting also revealed outdated service versions.

```
user@AttackBox$ traceroute tryhackme.com
traceroute to tryhackme.com (172.67.69.208), 30 hops max, 60 byte packets
 1 ec2-3-248-240-5.eu-west-1.compute.amazonaws.com (3.248.240.5) 2.663 ms * ec2-3-248-240-
 2 100.66.8.86 (100.66.8.86) 43.231 ms 100.65.21.64 (100.65.21.64) 18.886 ms 100.65.22.160
 3 * 100.66.16.176 (100.66.16.176) 8.006 ms *
 4 100.66.11.34 (100.66.11.34) 17.401 ms 100.66.10.14 (100.66.10.14) 23.614 ms 100.66.19.2
 5 100.66.7.35 (100.66.7.35) 12.808 ms 100.66.6.109 (100.66.6.109) 14.791 ms *
 6 100.65.14.131 (100.65.14.131) 1.026 ms 100.66.5.189 (100.66.5.189) 19.246 ms 100.66.5.2
 7 100.65.13.143 (100.65.13.143) 14.254 ms 100.95.18.131 (100.95.18.131) 0.944 ms 100.95.2
 8 100.95.2.143 (100.95.2.143) 0.680 ms 100.100.4.46 (100.100.4.46) 1.392 ms 100.95.18.143
 9 100.100.20.76 (100.100.20.76) 7.819 ms 100.92.11.36 (100.92.11.36) 18.669 ms 100.100.20
10 100.92.11.112 (100.92.11.112) 17.852 ms * 100.92.11.158 (100.92.11.158) 16.687 ms
11 100.92.211.82 (100.92.211.82) 19.713 ms 100.92.0.126 (100.92.0.126) 18.603 ms 52.93.112
12 99.83.69.207 (99.83.69.207) 17.603 ms 15.827 ms 17.351 ms
13 100.92.9.83 (100.92.9.83) 17.894 ms 100.92.79.136 (100.92.79.136) 21.250 ms 100.92.9.1
14 172.67.69.208 (172.67.69.208) 17.976 ms 16.945 ms 100.92.9.3 (100.92.9.3) 17.709 ms

user@AttackBox$ traceroute tryhackme.com
traceroute to tryhackme.com (172.67.69.208), 30 hops max, 60 byte packets
 1 ec2-79-125-1-9.eu-west-1.compute.amazonaws.com (79.125.1.9) 1.475 ms * ec2-3-248-240-31.eu-west-1.compute.amazonaws.com (3.
 2 100.65.20.180 (100.65.20.180) 16.575 ms 100.66.8.226 (100.66.8.226) 23.241 ms 100.65.23.152 (100.65.23.152) 22.267 ms
 3 100.65.16.50 (100.65.16.50) 2.777 ms 100.66.11.34 (100.66.11.34) 22.238 ms 100.65.16.20 (100.65.16.20) 4.421 ms
 4 100.66.6.47 (100.66.6.47) 17.264 ms 100.66.7.161 (100.66.7.161) 39.562 ms 100.66.10.198 (100.66.10.198) 15.958 ms
 5 100.66.5.123 (100.66.5.123) 20.899 ms 100.66.7.239 (100.66.7.239) 19.253 ms 100.66.5.59 (100.66.5.59) 15.397 ms
 6 * 100.66.5.223 (100.66.5.223) 26.172 ms 100.65.15.135 (100.65.15.135) 8.424 ms
 7 100.65.12.135 (100.65.12.135) 0.390 ms 100.65.12.15 (100.65.12.15) 1.045 ms 100.65.14.15 (100.65.14.15) 1.036 ms
 8 100.100.4.16 (100.100.4.16) 0.482 ms 100.100.20.122 (100.100.20.122) 0.795 ms 100.95.2.143 (100.95.2.143) 0.827 ms
 9 100.100.20.86 (100.100.20.86) 0.442 ms 100.100.4.78 (100.100.4.78) 0.347 ms 100.100.20.20 (100.100.20.20) 1.388 ms
10 100.92.212.20 (100.92.212.20) 11.611 ms 100.92.11.54 (100.92.11.54) 12.675 ms 100.92.11.56 (100.92.11.56) 10.835 ms
11 100.92.6.52 (100.92.6.52) 11.427 ms 100.92.6.50 (100.92.6.50) 11.033 ms 100.92.210.50 (100.92.210.50) 10.551 ms
12 100.92.210.139 (100.92.210.139) 10.406 ms 100.92.6.13 (100.92.6.13) 14.586 ms 100.92.210.69 (100.92.210.69) 12.032 ms
13 100.92.79.12 (100.92.79.12) 12.611 ms 100.92.79.68 (100.92.79.68) 11.318 ms 100.92.80.84 (100.92.80.84) 18.496 ms
14 100.92.9.27 (100.92.9.27) 11.354 ms 100.92.80.31 (100.92.80.31) 13.000 ms 52.93.135.81 (52.93.135.81) 10.941 ms 150.222.241.87 (150.222.241.87) 16.543 ms
15 150.222.241.85 (150.222.241.85) 9.660 ms 52.93.135.81 (52.93.135.81) 10.941 ms 150.222.241.87 (150.222.241.87) 16.543 ms
16 100.92.228.182 (100.92.228.182) 15.168 ms 100.92.227.41 (100.92.227.41) 10.154 ms 100.92.227.53 (100.92.227.53) 11.750 ms
17 100.92.232.111 (100.92.232.111) 10.589 ms 100.92.231.69 (100.92.231.69) 16.664 ms 100.92.232.37 (100.92.232.37) 13.089 ms
18 100.91.205.140 (100.91.205.140) 11.551 ms 100.91.201.62 (100.91.201.62) 10.246 ms 100.91.201.36 (100.91.201.36) 11.368 ms
19 100.91.205.79 (100.91.205.79) 11.112 ms 100.91.205.43 (100.91.205.43) 11.040 ms 100.91.205.33 (100.91.205.33) 10.114 ms
20 100.91.211.45 (100.91.211.45) 9.486 ms 100.91.211.79 (100.91.211.79) 13.693 ms 100.91.211.47 (100.91.211.47) 13.619 ms
21 100.100.6.81 (100.100.6.81) 11.522 ms 100.100.68.70 (100.100.68.70) 10.181 ms 100.100.6.21 (100.100.6.21) 11.687 ms
22 100.100.65.151 (100.100.65.151) 10.371 ms 100.100.92.6 (100.100.92.6) 10.939 ms 100.100.65.70 (100.100.65.70) 23.705 ms
23 100.100.2.74 (100.100.2.74) 15.317 ms 100.100.66.17 (100.100.66.17) 11.492 ms 100.100.83.67 (100.100.83.67) 35.312 ms
24 100.100.16.16 (100.100.16.16) 19.155 ms 100.100.16.28 (100.100.16.28) 19.147 ms 100.100.2.68 (100.100.2.68) 13.718 ms
25 99.83.89.19 (99.83.89.19) 28.929 ms * 21.790 ms
26 174.26.11.229 (174.26.11.229) 11.870 ms 11.858 ms 11.982 ms
```

Security Impact

Exposed services allow attackers to gather intelligence about the environment and identify known vulnerabilities associated with those services. Attackers can use this information to perform targeted exploitation attempts.

Poorly configured or outdated services can lead to:

- Unauthorized access
- Information disclosure
- Remote code execution
- Lateral movement inside networks

Recommendations

To reduce risk, the following actions are recommended:

- Disable unnecessary services
- Restrict exposed ports using firewall rules
- Keep systems and services updated
- Limit public exposure of SMB services
- Implement network monitoring and intrusion detection systems

OWASP Juice Shop Assessment

Objective

The objective of the web application assessment was to identify common vulnerabilities affecting the OWASP Juice Shop application.

Process

Burp Suite was configured as a proxy to intercept and analyze HTTP requests between the browser and the web application. Authentication testing and input validation testing were performed during the assessment.

SQL Injection testing was conducted against the login functionality. By manipulating the login request with specially crafted SQL payloads, authentication bypass was successfully achieved.

The testing demonstrated that the application did not properly sanitize user input before processing backend SQL queries.

Findings

The following vulnerabilities were identified:

- SQL Injection vulnerability
- Weak authentication controls
- Insufficient input validation
- Sensitive information exposure

Using SQL Injection, administrator-level access was obtained without knowing valid credentials.

The image displays a series of screenshots from Burp Suite and OWASP Juice Shop, illustrating a successful SQL injection attack.

Top Left: Burp Suite - Snippet attack configuration

Target: http://10.48.163.21

Update Host header to match target

1 Add 5 Clear 5 Auto 5

2 User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:131.0) Gecko/20100101 Firefox/131.0

3 Accept: application/json, text/plain, */*

4 Accept-Language: en-US,en;q=0.5

5 Accept-Encoding: gzip, deflate, br

6 Content-Type: application/json

7 Content-Length: 55

8 Origin: http://10.48.163.21

9 Connection: keep-alive

10 Referer: http://10.48.163.21/

11 Cookie: language=en, consent=status=dismiss; continueCode=W3R2g3B9skZvQ4uE0t55YdEhY3uaeGoyJRWrdZVpP8b73uakvk

12 Priority: u=0

13 ("email": "admin@juice-sh.op", "password": "asdfasdfasdf")

14 Add from list... [Pro version only]

15 Deduplicate

Event log All issues 1 highlight 1 payload position Length: 592 Memory: 161.9MB

Top Right: Burp Suite - Intruder attack results

2. Intruder attack of http://10.48.163.21

Attack Save

Results Positions

Request	Payload	Status code	Response recs...	Error	Timeout	Length	Comment
117	admin123	200	32			1202	
1	----	401	32				
2	0	401	17			413	
3	00000	401	26			413	
4	000000	401	20			413	
5	0000000	401	23			413	
6	00000000	401	25			413	

Bottom Left: Burp Suite - Network tab

10.48.163.21

1234567891011121314151617181920212223242526272829303132333435363738394041424344454647484950515253545556575859606162636465666768697071727374757677787980818283848586878889909192939495969798991001011021031041051061071081091101111121131141151161171181191201211221231241251261271281291301311321331341351361371381391401411421431441451461471481491501511521531541551561571581591601611621631641651661671681691701711721731741751761771781791801811821831841851861871881891901911921931941951961971981992002012022032042052062072082092102112122132142152162172182192202212222232242252262272282292302312322332342352362372382392402412422432442452462472482492502512522532542552562572582592602612622632642652662672682692702712722732742752762772782792802812822832842852862872882892902912922932942952962972982993003013023033043053063073083093103113123133143153163173183193203213223233243253263273283293303313323333343353363373383393403413423433443453463473483493503513523533543553563573583593603613623633643653663673683693703713723733743753763773783793803813823833843853863873883893903913923933943953963973983994004014024034044054064074084094104114124134144154164174184194204214224234244254264274284294304314324334344354364374384394404414424434444454464474484494504514524534544554564574584594604614624634644654664674684694704714724734744754764774784794804814824834844854864874884894904914924934944954964974984995005015025035045055065075085095105115125135145155165175185195205215225235245255265275285295305315325335345355365375385395405415425435445455465475485495505515525535545555565575585595605615625635645655665675685695705715725735745755765775785795805815825835845855865875885895905915925935945955965975985996006016026036046056066076086096106116126136146156166176186196206216226236246256266276286296306316326336346356366376386396406416426436446456466476486496506516526536546556566576586596606616626636646656666676686696706716726736746756766776786796806816826836846856866876886896906916926936946956966976986997007017027037047057067077087097107117127137147157167177187197207217227237247257267277287297307317327337347357367377387397407417427437447457467477487497507517527537547557567577587597607617627637647657667677687697707717727737747757767777787797807817827837847857867877887897907917927937947957967977987998008018028038048058068078088098108118128138148158168178188198208218228238248258268278288298308318328338348358368378388398408418428438448458468478488498508518528538548558568578588598608618628638648658668678688698708718728738748758768778788798808818828838848858868878888898908918928938948958968978988999009019029039049059069079089099109119129139149159169179189199209219229239249259269279289299309319329339349359369379389399409419429439449459469479489499509519529539549559569579589599609619629639649659669679689699709719729739749759769779789799809819829839849859869879889899909919929939949959969979989991000100110021003100410051006100710081009101010111012101310141015101610171018101910201021102210231024102510261027102810291030103110321033103410351036103710381039104010411042104310441045104610471048104910501051105210531054105510561057105810591060106110621063106410651066106710681069107010711072107310741075107610771078107910801081108210831084108510861087108810891090109110921093109410951096109710981099110011011102110311041105110611071108110911101111112111311141115111611171118111911201121112211231124112511261127112811291130113111321133113411351136113711381139114011411142114311441145114611471148114911501151115211531154115511561157115811591160116111621163116411651166116711681169117011711172117311741175117611771178117911801181118211831184118511861187118811891190119111921193119411951196119711981199120012011202120312041205120612071208120912101211121212131214121512161217121812191220122112221223122412251226122712281229123012311232123312341235123612371238123912401241124212431244124512461247124812491250125112521253125412551256125712581259126012611262126312641265126612671268126912701271127212731274127512761277127812791280128112821283128412851286128712881289129012911292129312941295129612971298129913001301130213031304130513061307130813091310131113121313131413151316131713181319132013211322132313241325132613271328132913301331133213331334133513361337133813391340134113421343134413451346134713481349135013511352135313541355135613571358135913601361136213631364136513661367136813691370137113721373137413751376137713781379138013811382138313841385138613871388138913901391139213931394139513961397139813991400140114021403140414051406140714081409141014111412141314141415141614171418141914201421142214231424142514261427142814291430143114321433143414351436143714381439144014411442144314441445144614471448144914501451145214531454145514561457145814591460146114621463146414651466146714681469147014711472147314741475147614771478147914801481148214831484148514861487148814891490149114921493149414951496149714981499150015011502150315041505150615071508150915101511151215131514151515161517151815191520152115221523152415251526152715281529153015311532153315341535153615371538153915401541154215431544154515461547154815491550155115521553155415551556155715581559156015611562156315641565156615671568156915701571157215731574157515761577157815791580158115821583158415851586158715881589159015911592159315941595159615971598159916001601160216031604160516061607160816091610161116121613161416151616161716181619162016211622162316241625162616271628162916301631163216331634163516361637163816391640164116421643164416451646164716481649165016511652165316541655165616571658165916601661166216631664166516661667166816691670167116721673167416751676167716781679168016811682168316841685168616871688168916901691169216931694169516961697169816991700170117021703170417051706170717081709171017111712171317141715171617171718171917201721172217231724172517261727172817291730173117321733173417351736173717381739174017411742174317441745174617471748174917501751175217531754175517561757175817591760176117621763176417651766176717681769177017711772177317741775177617771778177917801781178217831784178517861787178817891790179117921793179417951796179717981799180018011802180318041805180618071808180918101811181218131814181518161817181818191820182118221823182418251826182718281829183018311832183318341835183618371838183918401841184218431844184518461847184818491850185118521853185418551856185718581859186018611862186318641865186618671868186918701871187218731874187518761877187818791880188118821883188418851886188718881889189018911892189318941895189618971898189919001901190219031904190519061907190819091910191119121913191419151916191719181919192019211922192319241925192619271928192919301931193219331934193519361937193819391940194119421943194419451946194719481949195019511952195319541955195619571958195919601961196219631964196519661967196819691970197119721973197419751976197719781979198019811982198319841985198619871988198919901991199219931994199519961997199819992000200120022003200420052006200720082009201020112012201320142015201620172018201920202021202220232024202520262027202820292030203120322033203420352036203720382039204020412042204320442045204620472048204920502051205220532054205520562057205820592060206120622063206420652066206720682069207020712072207320742075207620772078207920802081208220832084208520862087208820892090209120922093209420952096209720982099210021012102210321042105210621072108210921102111211221132114211521162117211821192120212121222123212421252126212721282129213021312132213321342135213621372138213921402141214221432144214521462147214821492150215121522153215421552156215721582159216021612162216321642165216621672168216921702171217221732174217521762177217821792180218121822183218421852186218721882189219021912192219321942195219621972198219922002201220222032204220522062207220822092210221122122213221422152216221722182219222022212222222322242225222622272228222922302231223222332234223522362237223822392240224122422243224422452246224722482249225022512252225322542255225622572258225922602261226222632264226522662267226822692270227122722273227422752276227722782279228022812282228322842285228622872288228922902291229222932294229522962297229822992300230123022303230423052306230723082309231023112312231323142315231623172318231923202321232223232324232523262327232823292330233123322333233423352336233723382339234023412342234323442345234623472348234923502351235223532354235523562357235823592360236123622363236423652366236723682369237023712372237323742375237623772378237923802381238223832384238523862387238823892390239123922393239423952396239723982399240024012402240324042405240624072408240924102411241224132414241524162417241824192420242124222423242424252426242724282429243024312432243324342435243624372438243924402441244224432444244524462447244824492450245124522453245424552456245724582459246024612462246324642465246624672468246924702471247224732474247524762477247824792480248124822483248424852486248724882489249024912492249324942495249624972498249925002501250225032504250525062507250825092510251125122513251425152516251725182519252025212522252325242525252625272528252925302531253225332534253525362537253825392540254125422543254425452546254725482549255025512552255325542555255625572558255925602561256225632564256525662567256825692570257125722573257425752576257725782579258025812582258325842585258625872588258925902591259225932594259525962597259825992600260126022603260426052606260726082609261026112612261326142615261626172618261926202621262226232624262526262627262826292630263126322633263426352636263726382639264026412642264326442645264626472648264926502651265226532654265526562657265826592660266126622663266426652666266726682669267026712672267326742675267626772678267926802681268226832684268526862687268826892690269126922693269426952696269726982699270027012702270327042705270627072708270927102711271227132714271527162717271827192720272127222723272427252726272727282729273027312732273327342735273627372738273927402741274227432744274527462747274827492750275127522753275427552756275727582759276027612762276327642765276627672768276927702771277227732774277527762777277827792780278127822783278427852786278727882789279027912792279327942795279627972798279928002801280228032804280528062807280828092810281128122813281428152816281728182819282028212822282328242825282628272828282928302831283228332834283528362837283828392840284128422843284428452846284728482849285028512852285328542855285628572858285928602861286228632864286528662867286828692870287128722873287428752876287728782879288028812882288328842885288628872888288928902891289228932894289528962897289828992900290129022903290429052906290729082909291029112912291329142915291629172918291929202921292229232924292529262927292829292930293129322933293429352936293729382939294029412942294329442945294629472948294929502951295229532954295529562957295829592960296129622963296429652966296729682969297029712972297329742975297629772978297929802981298229832984298529862987298829892990299129922993299429952996299729982999300030013002300330043005300630073008300930103011301230133014301530163017301830193020302130223023302430253026302730283029303030313032303330343035303630373038303930403041304230433044304530463047304830493050305130523053305430553056305730583059306030613062306330643065306630673068306930

- Bypass authentication mechanisms
- Access sensitive database information
- Modify or delete application data
- Escalate privileges
- Potentially gain server access

Weak input validation increases the likelihood of application compromise and unauthorized access.

Recommendations

The following mitigation steps are recommended:

- Use parameterized SQL queries
- Implement server-side input validation
- Sanitize all user inputs
- Deploy a Web Application Firewall (WAF)
- Conduct secure code reviews
- Implement strong authentication controls
- Perform regular security assessments

Blue Room Exploitation

Objective

The objective of the Blue Room assessment was to identify and exploit vulnerabilities affecting a Windows machine in an authorized testing environment.

Process

The assessment began with Nmap scanning and SMB enumeration. The scans revealed that the target system was vulnerable to MS17-010, commonly known as EternalBlue.

Metasploit Framework was used to configure and launch the EternalBlue exploit against the target machine. After successful exploitation, a Meterpreter shell session was established, providing remote administrative access to the system.

Post-exploitation activities included navigating the system and retrieving proof-of-access flags from authorized directories.

Findings

The target machine was vulnerable to:

- MS17-010 EternalBlue
- SMBv1 exposure

Successful exploitation allowed remote code execution and complete compromise of the Windows system.

Security Impact

The EternalBlue vulnerability is considered critical because it allows attackers to remotely execute arbitrary code without authentication.

Successful exploitation may allow attackers to:

- Deploy ransomware
- Gain full administrative access
- Steal sensitive information
- Move laterally across networks
- Disrupt business operations

Systems vulnerable to EternalBlue are highly exposed to real-world cyberattacks.

Recommendations

The following actions are strongly recommended:

- Apply Microsoft security patches immediately
- Disable SMBv1 protocol
- Restrict SMB access using firewall rules
- Conduct regular vulnerability scanning
- Implement endpoint detection and response (EDR)
- Maintain an effective patch management process

Overall Conclusion

The penetration testing engagement successfully identified multiple vulnerabilities affecting both the web application and Windows infrastructure environments.

The assessment demonstrated how attackers can leverage weak configurations, outdated services, and insecure coding practices to compromise systems and gain unauthorized access.

The most critical findings included:

- SQL Injection vulnerabilities
- Weak authentication mechanisms
- MS17-010 EternalBlue vulnerability
- SMBv1 exposure

These vulnerabilities could potentially lead to:

- Unauthorized access
- Data breaches
- Full system compromise
- Malware deployment
- Service disruption

Implementing the recommended security controls, patch management practices, and secure development standards will significantly improve the organization's overall security posture and reduce the likelihood of successful cyberattacks in the future.